

LEVEL 1 COURSE

WINDOWS SECURITY BASICS

Comprehensive Investigation & Analysis for SOC Analysts

INSTRUCTOR: NADER ANAM // **MODULE:** 03

LEARNING OBJECTIVES



CORE COMPONENTS

Understand Users, Groups, Privileges, Processes, and Services from a SOC lens.



EVENT MECHANICS

Master Windows Event IDs and the Event Viewer for rapid log analysis.



THREAT DETECTION

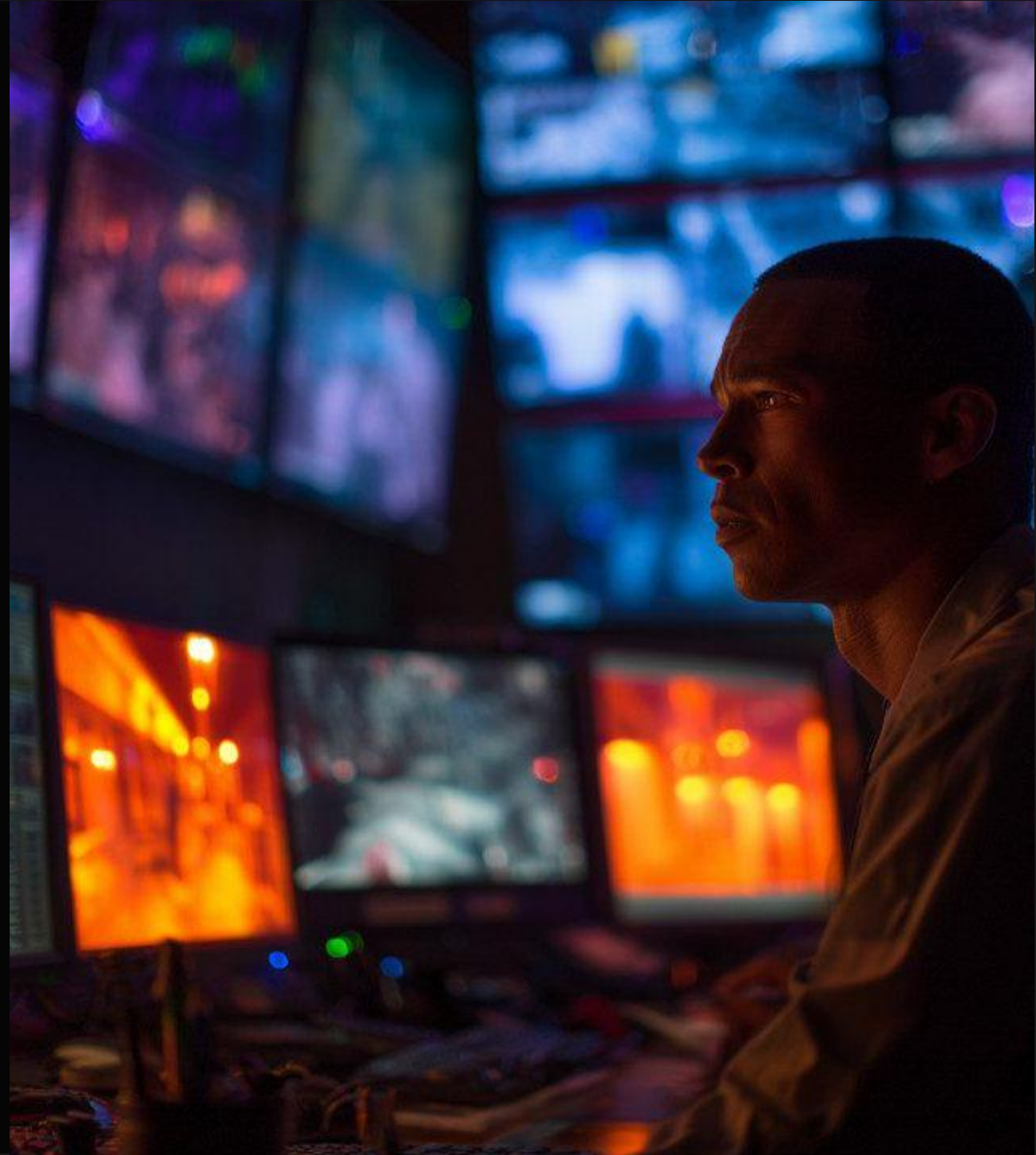
Identify Brute Force, Persistence, and Privilege Escalation through practical scenarios.

WHY WINDOWS MATTERS

The vast majority of enterprise environments rely on Windows for workstations and servers. Most security alerts originate here.

Visibility Gaps: A SOC Analyst who cannot interpret Windows Logs loses 90% of the investigative picture.

Critical data flows from Active Directory, PowerShell, and Endpoint Detection platforms.



| THE SOC MINDSET VS. SYSADMIN

WE DON'T STUDY MAINTENANCE...

We study **Investigation**. Our questions are different:

- ▶ Who logged in and at what time?
- ▶ Was the login successful or a failure?
- ▶ Did a process spawn a suspicious child?
- ▶ Were high-privilege groups modified?
- ▶ Were audit logs cleared to hide tracks?
- ▶ Is there a persistence mechanism in place?

| KEY INVESTIGATIVE PILLARS

IDENTITY

Users, Groups, and Privileges.

EXECUTION

Processes, Services, and
PowerShell.

PERSISTENCE

Registry and Scheduled Tasks.

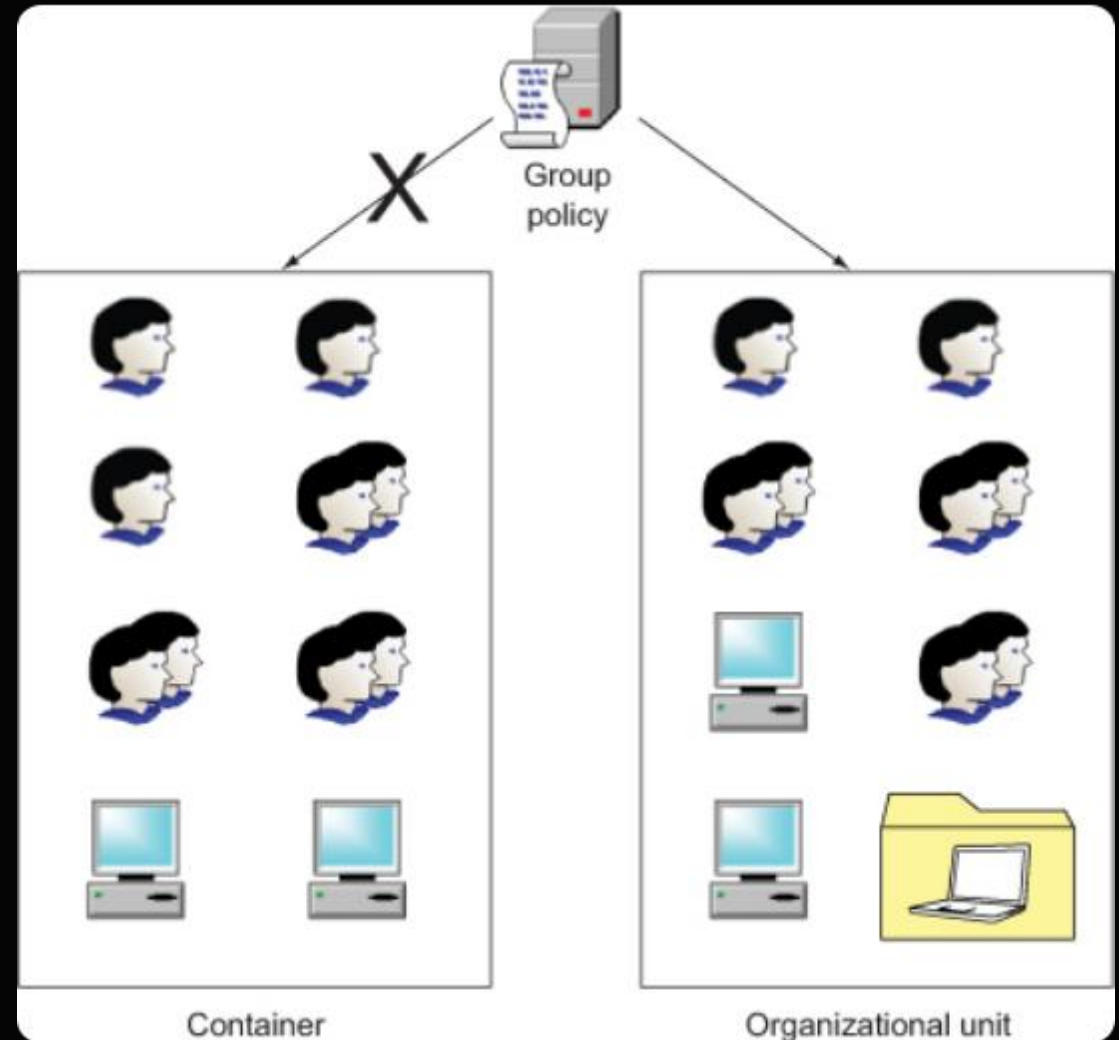
WINDOWS USERS

A **User** is an identity used to log in, run services, or execute commands.

- **Standard User:** Limited permissions.
- **Administrator:** High control over local system.
- **Service Account:** Runs non-interactive tasks.
- **Domain Account:** Controlled by Active Directory.

SOC Check: Is the user active? Is the location unusual?

Any high failure counts?



| HIGH-PRIVILEGE GROUPS

CRITICAL GROUPS

05

DANGEROUS TARGETS

Mailing a user to a sensitive group is a massive red flag. Groups to monitor:

- **Administrators** (Local)
- **Domain Admins** (Enterprise-wide)
- **Enterprise Admins**
- **Remote Desktop Users**
- **Backup Operators**

*Event: User "ali" added to "Domain Admins". This is an **Incident** until proven otherwise.*

| PRIVILEGES & IMPACT

Privilege determines what a user CAN do. High-privilege accounts allow attackers to:

- Disable Antivirus or EDR sensors.
- Access sensitive database/file shares.
- Wipe Security Logs (Event 1102).
- Modify System configurations.

Rule: Compromising an Admin account is the "Game Over" for the host.



| ACCOUNTS IN INVESTIGATION

Attacks start with accounts. Look for these vectors:

-  **Brute Force:** High failures against a single target.
-  **Password Spraying:** One password tried against many users.
-  **Lateral Movement:** One account logging into multiple servers.
-  **Privilege Escalation:** Standard user becomes Admin.

| WHAT IS A PROCESS?

A **Process** is an active instance of a program. SOC analysts look for anomalies:

CHROME.EXE

Normal web browsing, but check for weird network connections.

POWERSHELL.EXE

High administrative power; often used for fileless malware.

SVCHOST.EXE

System service host; often spoofed by malware using similar names.

PROCESS ANOMALY INDICATORS

Indicator	Suspicion Level	Why?
powershell -enc	High	Encoded command hiding malicious intent.
cmd /c whoami	Medium	Reconnaissance after initial breach.
exe in \AppData	High	Common path for malware to avoid Admin prompts.
word -> powershell	Critical	Macro-enabled phishing document execution.

WINDOWS SERVICES

A **Service** runs in the background. Attackers use services for **Persistence** (staying in the system after reboot).

Red Flag: A new service named "WindowsUpdateHelper" running from C:\Users\Public\update.exe.

Legitimate services rarely run from \Public folders.

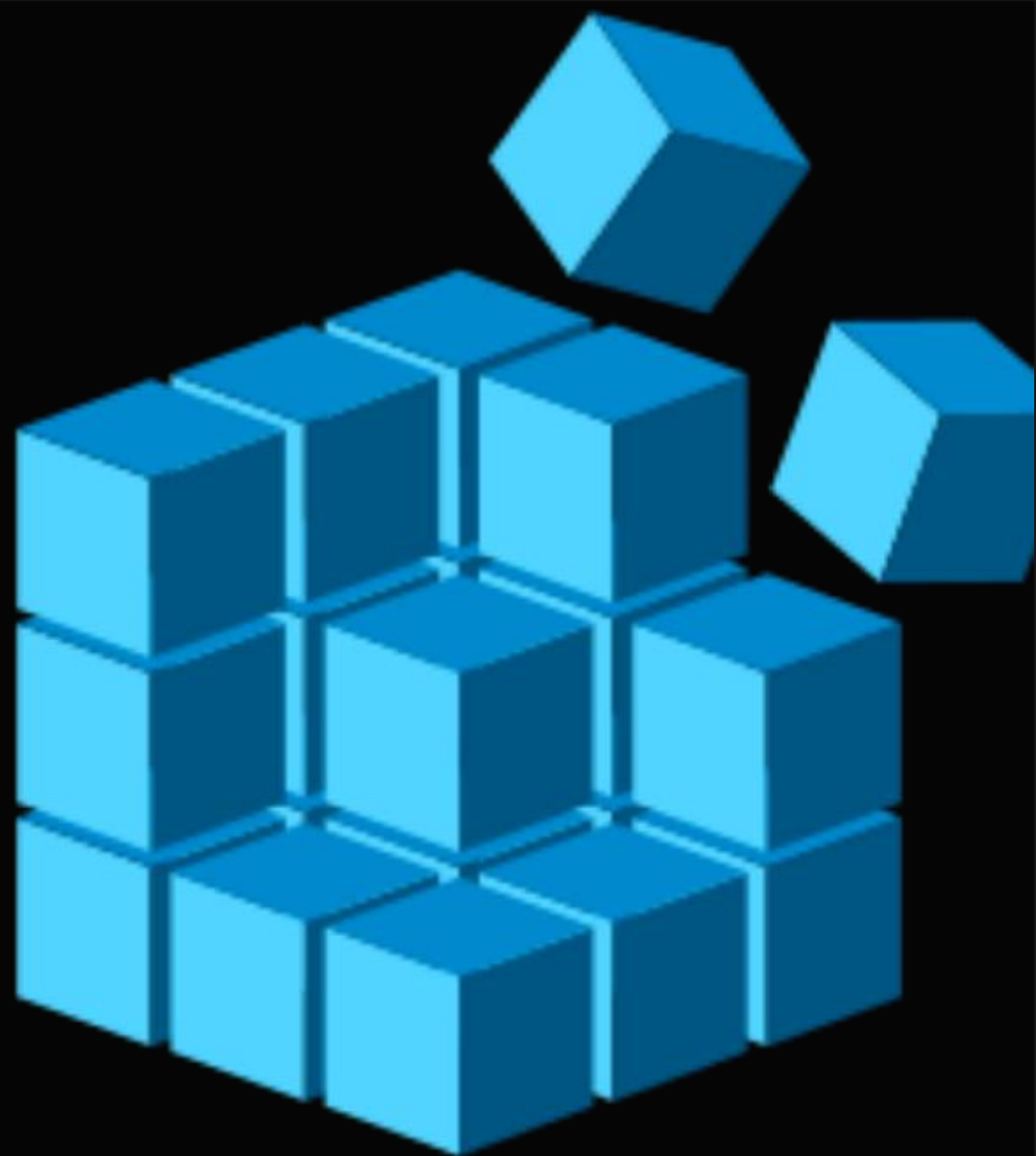


WINDOWS REGISTRY

The central database for system and user settings.
It is the gold mine for persistence.

- **Run Keys:** Executing files on login.
- **Security Disabling:** Turning off AV.
- **Storage:** Hiding scripts in registry keys.

SOC Tip: Monitor the HKLM\...\Run and RunOnce keys.



| SCHEDULED TASKS

Tasks allow programs to run at specific times or events.

Offensive Use:

- Run malware on every user login.
- Execute C2 beaconing scripts every hour.
- Re-install malware if the main file is deleted.

A new, unknown task is a primary indicator of persistence.



POWERSHELL MECHANICS

PowerShell is a powerful admin tool, making it the perfect "living off the land" (LotL) weapon for attackers.

Attacker's Goal: Execute commands entirely in memory without leaving files on the disk.

SOC analysts must monitor **Script Block Logging** to see the deobfuscated commands.



| POWERSHELL INDICATORS

-ENC / - ENCODEDCOMMAND

Base64 encoded commands used to hide malicious logic from AV scanners.

INVOKE-WEBREQUEST

Downloads malicious payloads or second-stage malware from the internet.

IEX (INVOKE-EXPRESSION)

Executes strings as code; the hallmark of fileless script execution.

THE EVENT VIEWER

The "Black Box"
of Windows.

Categories for
SOC:

- **Security:**

Logons,
account
changes,

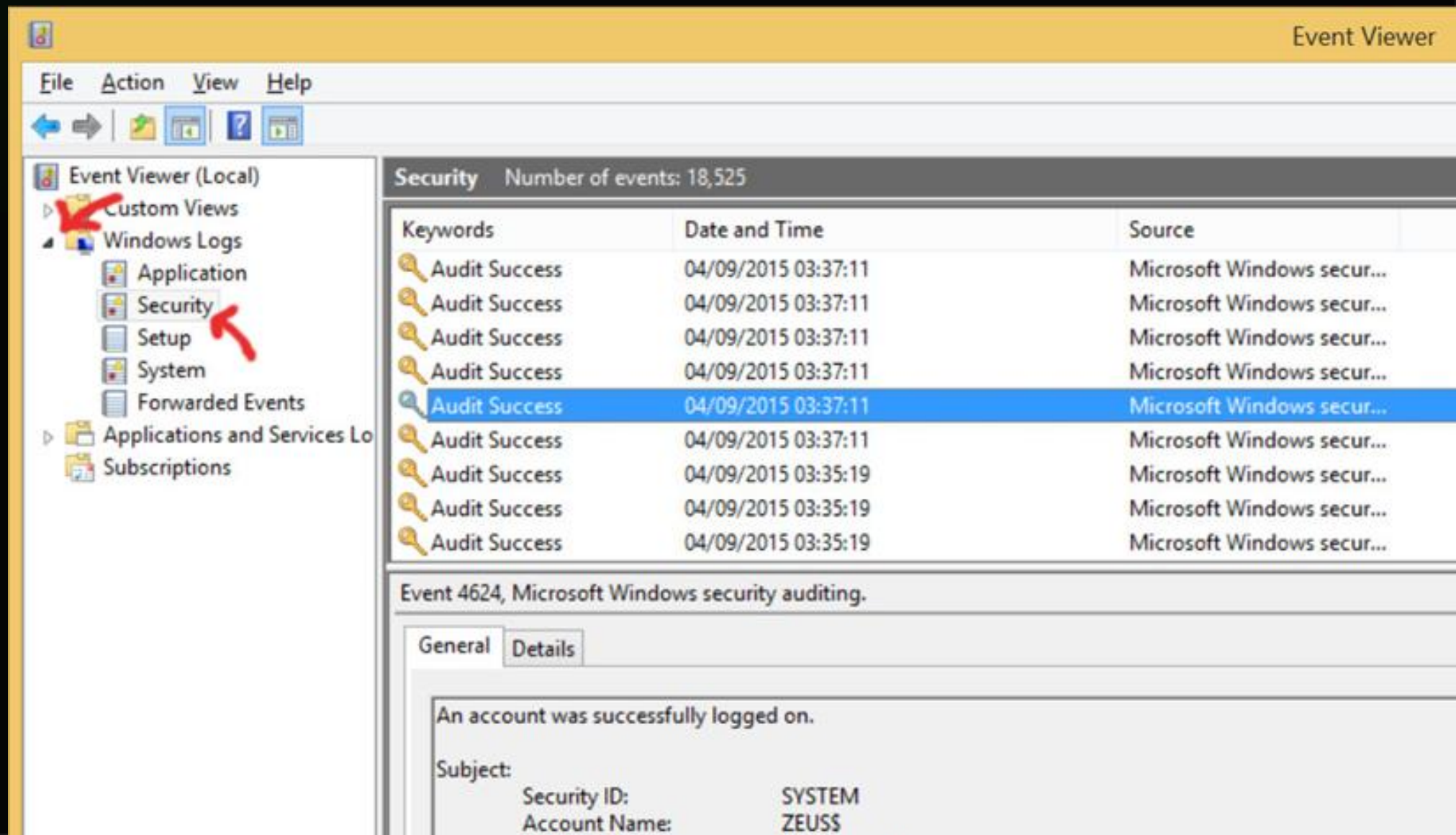
- **Policy:**

edits,
service

installs,
reboots,

- **PowerShell**

Script



| UNDERSTANDING EVENT IDS

An **Event ID** is a unique number identifying a specific activity type. This is how SIEMs filter data.

4624

Successful Logon.

4625

Failed Logon.

4688

Process Creation.

ESSENTIAL EVENT ID MATRIX

Event ID	Meaning	Analytic Value
4624 / 4625	Success / Failed Logon	Credential monitoring.
4672	Special Privileges	High-risk account login.
4720	User Created	Unauthorized account creation.
4728 / 4732	Added to Group	Privilege escalation check.
1102	Audit Log Cleared	Critical: Cover-up attempt.

| ID 4624: SUCCESSFUL LOGON

A user successfully entered the system. Watch these fields:

ACCOUNT NAME

Who logged in? Is it an Admin?

LOGON TYPE

How did they log in? (Remote vs. Local).

SOURCE IP

From where? Internal or External?

| ID 4625: FAILED LOGON

Indicates a failed attempt. One is normal; 50 is an **Incident**.

FAILURE REASON

Bad password vs. Unknown user.

LOGON TYPE

Network logon failures suggest automation.

WORKSTATION

Which machine was targeted?

| ID 4672: SPECIAL PRIVILEGES

ADMIN

ASSIGNED

This event triggers when a user is granted administrative rights during logon.

SOC Pivot: If this triggers for a "Normal" user outside business hours, investigate for **Privilege Escalation**.

| ID 4688: PROCESS CREATION

The heart of post-exploitation analysis. It shows what ran after the login.

PROCESS NAME

cmd.exe, powershell.exe, etc.

PARENT PROCESS

Who started it? (e.g., outlook.exe spawning cmd.exe is bad).

COMMAND LINE

The exact arguments used
(Critical for decoding -enc).

| ID 4720: PERSISTENCE MONITORING

Unauthorized user creation is a classic persistence technique. Analyze:

 **Creator:** Who created this account? (Standard users shouldn't).

 **Account Name:** Does it sound like a system account (e.g., svc_admin)?

 **Timing:** Was it created at 2 AM on a Sunday?

| ID 4728/4732: ESCALATION

User added to a security-enabled group. **4728** is for Domain, **4732** is for Local.

TARGET GROUP

Usually Domain Admins or
Local Administrators.

MEMBER NAME

Which user was elevated?

SUBJECT

The user who performed the
elevation.

| ID 1102: AUDIT LOG CLEARED

WIPE

AUDIT LOG

This is the **Red Alert** of Windows logs. There is almost no legitimate reason to clear security logs in production.

Analytic Path: Identify the user who cleared the log. This user is your **Primary Suspect** for an active breach.

CRITICAL LOGON TYPES

Type	Meaning	SOC Analysis
2	Interactive	Physically sitting at the keyboard.
3	Network	Accessing a share or service over the network.
7	Unlock	Opening a locked screen.
10	Remote Interactive	RDP: Most common for external attacks.
11	Cached	Logging in with stored credentials (Offline).

| IMPORTANCE OF TYPE 10

If you see **Logon Type 10** from a non-corporate IP address at 3 AM, you are looking at an active **RDP Breach**.

CHECK SOURCE IP

VPN vs Public IP.

CHECK TIME

Outside shift hours.

CHECK USER ROLE

Finance vs IT Admin.

| SCENARIO 1: FAILED LOGINS

TELEMETRY

User: ahmed

Attempts: 25 failures

Source: 185.44.10.20

Success After: **NO**

ANALYSIS

Outcome: External Brute Force attempt identified.

Severity: **Medium**.

Action: Close after documentation & IP monitoring.

| SCENARIO 2: SUCCESS AFTER FAILURE

TELEMETRY

User: finance.manager

Attempts: 18 failures

Success After: **YES**

Time: 01:40 AM

ANALYSIS

Outcome: Account Compromise.

Severity: **High**.

Action: **Escalate to Tier 2**. Reset password, isolate host.

BRUTE FORCE ATTACKS

Attackers repeatedly try many passwords against a single account until success or lockout.

Indicator: Rapid succession of 4625 events targeting one user from a single Source IP.

Leads to **Account Lockout (4740)**, disrupting business operations.



The image shows a login page with a grey header bar containing the word "Login". Below this is a white area with a pink bar containing the text "Please sign-in". Underneath, there are two input fields: "Name" and "Password". Below the "Password" field is a blue button labeled "Login". At the bottom, there is a link that says "If you don't have an account? Please register here".

PASSWORD SPRAYING

Instead of attacking one user with many passwords, attackers try **one common password** against **hundreds of users**.

STEALTH

Avoids locking accounts by staying under the threshold.

EFFICIENCY

Increased probability of hitting a weak "Winter2024!" password.

DETECTION

Look for single failed attempts across many accounts from one IP.

| BRUTE FORCE VS. SPRAYING

BRUTE FORCE PATTERN

One User → Many Passwords

Result: 4740 Account Lockout.

SPRAYING PATTERN

One Password → Many Users

Result: Multiple 4625s across domain.

| AUTHENTICATION ALERT CHECKLIST

Gather these details for every authentication investigation:

- ✓ **Username:** Is this a VIP or admin account?
- ✓ **Logon Type:** Is it Type 10 (RDP) or Type 2 (Console)?
- ✓ **Source IP:** Reputable location or foreign proxy?
- ✓ **Success:** Did the sequence end in a successful login?

| POST-LOGIN: THE REAL HUNTING

If a suspicious login occurs, your investigation **starts** there. What did they do next?

DISCOVERY

Did they run whoami or net user?

PERSISTENCE

Did they create a user or scheduled task?

EXFILTRATION

Did they connect to a foreign IP with high data volume?

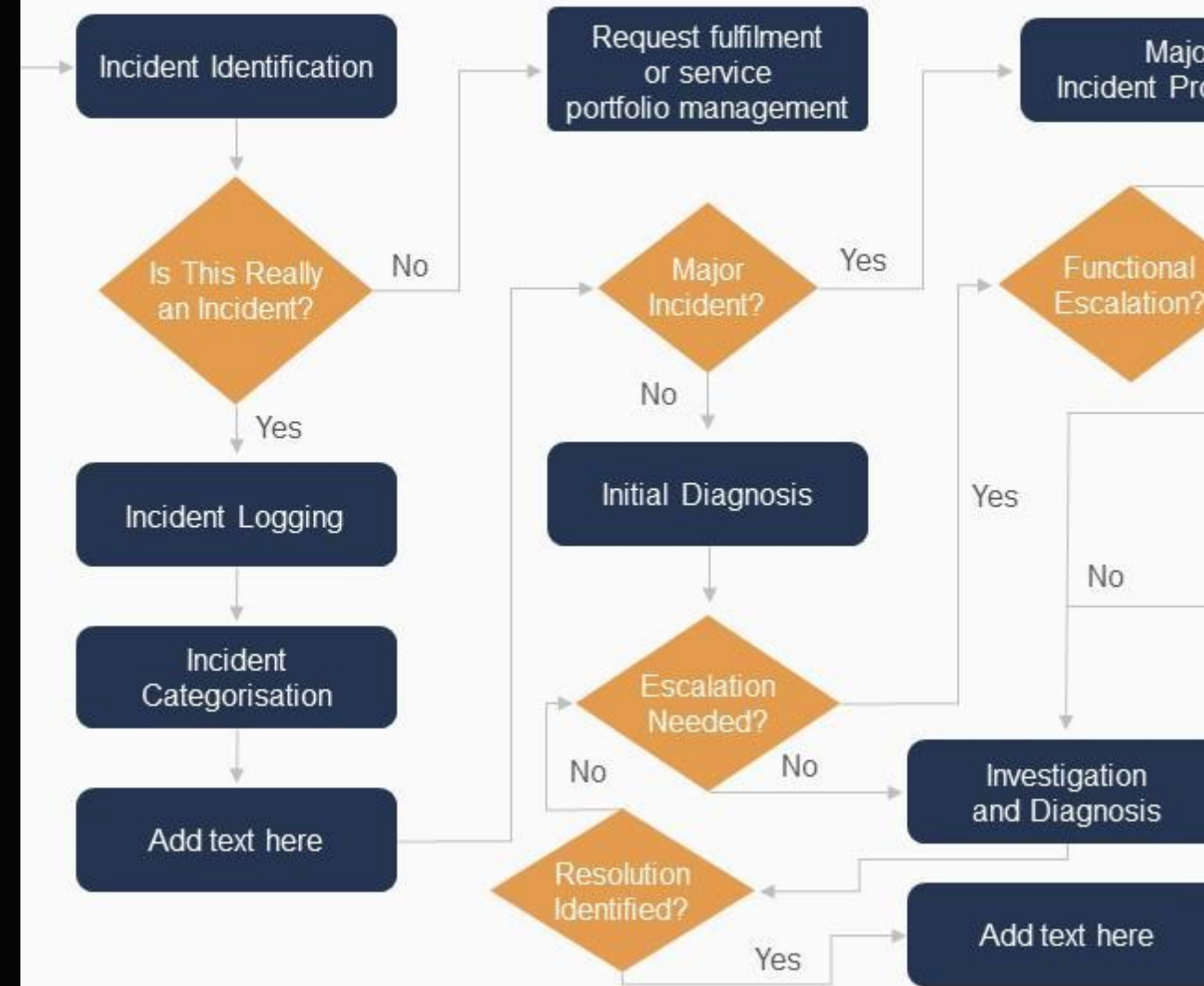
INVESTIGATION TEMPLATE

Consistency is key. Use this structured approach for every Windows alert:

```
User: [Name] | Host: [AssetID]
Event IDs: [e.g., 4625, 4624]
Source: [IP Address]
Activity: [Narrative of actions]
Decision: [Escalate / Close]
Justification: [Evidence Log IDs]
```

Chart for ITSM incident management

Chart for ITSM incident management process which helps to identify and eliminate potential error to restore normal service. web interfaces, incident prioritisation, resolution and recovery, etc.



| DRILL 1: ANALYSIS

INPUT LOG

User: khaled

Attempts: 5 failures

Time: 10:30 AM

Success: **NO**

QUESTIONS

1. Is this an incident?
2. What is the severity?
3. Close or Escalate?

| DRILL 1: SOLUTION

ANSWER

Outcome: Benign User Error.

Severity: **Low**.

RATIONALE

Low attempt count during business hours with no successful login.

Decision: **CLOSE**.

| DRILL 2: ANALYSIS

INPUT LOG

User: admin.support
Attempts: 30 failures
Success: **YES**
Logon Type: 10

QUESTIONS

1. What is the threat?
2. Why is Type 10 critical?
3. Final Decision?

| DRILL 2: SOLUTION

ANSWER

Threat: Account Compromise.

Severity: **Critical**.

RATIONALE

Successful RDP login after Brute Force on an admin account.

Decision: **ESCALATE**.

DRILL 3: ANALYSIS

INPUT LOG

Event: 4720 (Created)

Account: backup_admin

Creator: user01

Time: 11:50 PM

QUESTIONS

1. Why is this a red flag?
2. What persistence is this?
3. Close or Escalate?

| DRILL 3: SOLUTION

ANSWER

Threat: Backdoor Account.

Severity: **High**.

RATIONALE

Normal user creating an admin-sounding account at midnight.

Decision: **ESCALATE**.

DRILL 4: ANALYSIS

INPUT LOG

Event: 1102

Host: DC-01

User: administrator

Time: 03:05 AM

QUESTIONS

1. Is this ever normal?
2. What is the attacker doing?
3. Final Verdict?

DRILL 4: SOLUTION

Verdict: Active Breach / Covering Tracks.

Severity: **CRITICAL**.

Attackers wipe security logs on Domain Controllers to destroy evidence of their movement. **ESCALATE IMMEDIATELY.**



| WORKSHOP: GROUP ANALYSIS

Each squad will analyze a specialized log set and draft a triage report:

TEAM ALPHA

Analyze ID 4625 flood with NO success.

TEAM BRAVO

Analyze ID 4732: Normal user added to Admins.

TEAM DELTA

Analyze ID 4688: Encoded PowerShell from Word.

FULL TRAINING SCENARIO

Incident: Lateral Movement on HR-Laptop-12.

1. 24 failed logins on finance.manager.
2. Successful RDP login (Type 10).
3. Special Privileges Assigned (4672).
4. PowerShell -enc executed.
5. Outbound C2 connection every 60s.

Login

Please sign-in

Name

Password

Login

Don't have an account? [Please register here](#)

| SCENARIO ANALYSIS

What is the final verdict? Is this an incident?

VERDICT

Verified Account Compromise
& C2 Installation.

SEVERITY

CRITICAL - High Business
Impact.

ACTION

Isolate host, revoke tokens,
initiate full IR playbook.

| COMMON ANALYST MISTAKES

IGNORANCE

Ignoring "Success after Failure" patterns.

OVERSIGHT

Ignoring Logon Type 10 (RDP) from external IPs.

BUZZWORDS

Calling everything "Malware" without checking Command Lines.

| THE GOLDEN RULE

“

**"NEVER ANALYZE AN ID IN ISOLATION.
FIND THE STORY BEHIND THE LOGS."**

4625 → 4624 → 4672 → 4688 → 1102. That is a story. That is an incident.

SUMMARY

- ✓ Windows visibility is non-negotiable for Tier 1.
- ✓ Event IDs (4624, 4625, 4688) are your tools.
- ✓ Persistence lives in Services, Registry, and Tasks.
- ✓ Always verify "What ran after login?".



| REVIEW QUESTIONS

- ? What is the difference between Brute Force and Password Spraying?
- ? Why is Event ID 1102 considered a critical alert?
- ? What does Logon Type 10 tell you about an attacker?
- ? What is the danger of PowerShell -enc?

POP QUIZ: PART 1

Q1

Event ID 4624 means:

- A) Fail
- B) Success (Correct)

Q2

ID 4688 records:

- A) Process Creation (Correct)
- B) Shutdown

Q3

Type 10 Login is:

- A) Console
- B) Remote/RDP (Correct)

POP QUIZ: PART 2

Q4

Audit Log Cleared ID is:

- A) 1102 (Correct)
- B) 4720

Q5

User created ID is:

- A) 4720 (Correct)
- B) 4624

Q6

Spray uses:

- A) 1 Password (Correct)
- B) 100 Passwords

HOMework ASSIGNMENT

Task	Requirement
Scenario Matrix	Map 10 logs to their IDs and severity.
Triage Report	Draft a 5-line summary for a "Failed -> Success" alert.
PowerShell Check	Deobfuscate the Base64 command provided in the portal.

NEXT LECTURE

LINUX BASICS FOR SOC ANALYSTS

Mastering Auth.log, SSH, and the Root Privilege System.

| ADDITIONAL RESOURCES

LEARNING PORTALS

Microsoft Learn (SC-200), CyberDefenders, Blue Team Labs Online.

ESSENTIAL READING

"Windows Forensic Analysis" by Harlan Carvey, SANS Blue Team Field Guide.

IMAGE SOURCES



<https://images.presentationgo.com/2025/05/security-analyst-surveillance-room.jpg>

Source: www.presentationgo.com



<https://drek4537lklr.cloudfront.net/siddaway3/Figures/14fig01.jpg>

Source: livebook.manning.com



https://assets.content.technologyadvice.com/635222751547843164_ceadd34fae.webp

Source: null-byte.wonderhowto.com



<https://p1.hiclipart.com/preview/67/93/298/vista-folders-scheduled-tasks-icon-png-icon.jpg>

Source: www.hiclipart.com



https://upload.wikimedia.org/wikipedia/commons/thumb/0/0e/Windows_11_registry_editor_icon.svg/250px-Windows_11_registry_editor_icon.svg.png

Source: en.wikipedia.org



<https://az-icons.com/export/icons/4978c81f9cd7ce5001ee1b2f2b669ef5.svg>

Source: az-icons.com

IMAGE SOURCES



<https://i.sstatic.net/Hboyp.jpg>

Source: superuser.com



https://portswigger.net/support/images/owasp_authandsessionmanagement_1.png

Source: portswigger.net



https://www.slideteam.net/media/catalog/product/cache/1280x720/f/l/flowchart_for_itsm_incident_management_process_slide01.jpg

Source: www.slideteam.net



<https://igzy.com/wp-content/uploads/2021/07/Server-Room-Cameras.png>

Source: igzy.com